

Seguridad de la Información



Agenda Unidad 1

- ▶ Definiciones y Diferencias
- ▶ Triangulo CID
- ▶ Evolución tecnológica y efectos
- ▶ Conceptos de Seguridad Física y Lógica
- ▶ Introducción a Sistemas de Gestión de Seguridad de la Información: Políticas y Procedimientos de seguridad.
- ▶ Marcos de Referencia y Estándares: COBIT, ITIL, SOX, ISO 27001.
- ▶ Gestión del Riesgos sobre activos de información.



Por que es necesaria la
Seguridad de la
Informacion ?



Los sistemas Informáticos

Desde Inicio han sido vulnerables.

Control de Acceso:

- ▶ Físico
- ▶ Cuentas de Usuario



Surgimiento de las Redes

- ▶ Desafío para el Administrador
 - ▷ Perdida del control directo
- ▶ Mayor Tamaño
 - ▷ Mayor dificultad de control



Respondiendo a las preguntas ..

- ▶ La seguridad es lo que genera confianza en un sistema
 - ▶ Correo electrónico (ejemplo)
 - ▶ Demoró en tener validez legal (comparar correo postal)



Que significa que un sistema sea seguro ?

- ▶ Confidencialidad
- ▶ Integridad
- ▶ Disponibilidad



La Seguridad debe darse en diferentes niveles

- ▶ Equipos
- ▶ Red
- ▶ Software
- ▶ Personas



► Confidencialidad

La Información debe ser conocida solo por las partes interesadas.

Evitar que la información caiga en manos incorrectas

Ejemplos : Pedidos y transacciones por Internet



Crear cuenta

Tu nombre

Número de teléfono móvil o correo electrónico

Contraseña

i La contraseña debe contener al menos seis caracteres.

Vuelve a escribir la contraseña

Continuar

Al crear una cuenta, aceptas las [Condiciones de Uso](#) y el [Aviso de Privacidad](#) de amazon.com.

► Integridad

El sistema debe conservar su estado original

La información no debe dañarse (ni almacenada, ni en tránsito)

Ejemplos : Transferencias bancarias

Transferencia Bancaria

■ El mensaje de una transferencia bancaria

{1:F01MIDLGB22AXXX0548034693}{2:I103BKTRUS33XBRDN3}{3:{108:MT103}}{4:
:20:8861198-0706
:23B:CRED
:32A:030612USD5443,99
:33B:USD5443,99
:50K:GIAN ANGELO IMPORTS /
NAPLES
:52A:BCITITM500
:53A:BCITUS33
:54A:IRVTUS3N
:57A:BNPAFRPPGRE
:59:/20041010050500001M02606
KILLY S.A.
GRENOBLE
:70:/RFB/INVOICE 559661
:71A:SHA
-}{5:{MAC:3289381A}{CHK:4387208AF4E31}}



► Disponibilidad

El sistema debe estar disponible cuando se lo necesita

¿Qué significa estar disponible:

- ☐ 99% del tiempo?
 - 3 días y 14 horas al año fuera de servicio
- ☐ 99.9% del tiempo?
 - 8 horas y 45 minutos al año fuera de servicio

Esto Implica : COSTOS

► Seguridad de la Información

Minimizar la vulnerabilidad de un conjunto de sistemas

Medidas Proporcionales a lo que se quiere proteger

Importante: No es posible la seguridad total

Seguridad de la Información

- ▶ Alto nivel
 - ▷ Con la tecnología actual
- ▶ Aceptación social
 - ▷ Leyes
 - ▷ Regulaciones

Ejemplo: Comercio Electrónico



Las 5P de la Seguridad de la información

- ▶ Políticas
- ▶ Planes
- ▶ Productos
- ▶ Procesos
- ▶ Personas





Políticas

Punto de Referencia

Como alcanzar el objetivo si
no sabemos como

Clara y consistente con los
procesos de negocios

Divulgación y capacitación



Planes

Estrategias para
implementar la política

Consideraciones

No solo las aplicaciones
actuales.

Virtualización

Cloud



Productos

Tecnologías Claves para:

Ejecutar el Plan

Lograr los objetivos

Como deben configurarse
para:

Seguridad

Desempeño

Escalabilidad

Calidad de Servicio

Importancia del servicio al
Cliente

Procesos

Rutinas de administración

Métricas

Manejos de incidentes

Manejos de incidentes

- ▶ Monitorearse
- ▶ Someterse a pruebas
- ▶ Adaptarse



Personas

Quienes Implementaran el plan, los productos y los procesos.

Recurso crítico, frecuentemente no tenido en cuenta.

ISO27002 – Seguridad de la Información

- Política de seguridad
- Organización de la seguridad de la información
- Seguridad en los recursos humanos
- Gestión de activos
- Control de acceso
- Criptografía
- Seguridad física y ambiental
- Seguridad en las operaciones
- Seguridad en las comunicaciones
- Adquisición, desarrollo y mantenimiento de sistemas de información
- Relaciones con proveedores
- Gestión de incidentes
- Continuidad del negocio
- Cumplimiento con requisitos legales

ISO27002 – Seguridad informática

- Política de seguridad
- Organización de la seguridad de la información
- Seguridad en los recursos humanos
- Gestión de activos
- Control de acceso
- Criptografía
- Seguridad física y ambiental
- Seguridad en las operaciones
- Seguridad en las comunicaciones
- Adquisición, desarrollo y mantenimiento de sistemas de información
- Relaciones con proveedores
- Gestión de incidentes
- Continuidad del negocio
- Cumplimiento con requisitos legales

ISO27002 – Seguridad de la información

- Política de seguridad
- Organización de la seguridad de la información
- Seguridad en los recursos humanos
- Gestión de activos
- Control de acceso
- Criptografía
- Seguridad física y ambiental
- Seguridad en las operaciones
- Seguridad en las comunicaciones
- Adquisición, desarrollo y mantenimiento de sistemas de información
- Relaciones con proveedores
- Gestión de incidentes
- Continuidad del negocio
- Cumplimiento con requisitos legales

Cubre todo!

Decisiones sobre seguridad

- ▶ Que se quiere proteger
- ▶ De que
- ▶ Que tan bien se mitiga el riesgo
- ▶ Que otros riesgos se corren
- ▶ Que costos tiene la solución



Amenazas

- ▶ Violaciones potenciales de la seguridad.
- ▶ Cuatro tipos:
 - ▶ Destrucción de la información
 - ▶ Modificación de la información
 - ▶ Robo o Publicación Indebida
 - ▶ Interrupción del Servicio

Amenazas

- ▶ Accidentales
 - ▷ Falla del sistema
 - ▷ Error Humano
 - ▷ Catástrofes
- ▶ Intencionales:
 - ▷ Ataques

Vulnerabilidades

- ▶ Debilidades en un sistema de información
- ▶ Son susceptibles de ser atacadas
- ▶ Si no se remedian se pueden convertir en amenaza.

Ataques

- ▶ Activos
 - ▷ Alteran el comportamiento del recurso o servicio atacado
- ▶ Pasivos
 - ▷ No modifican el comportamiento del sistema.
 - ▷ Uso indebido de la información

Ataques : Suplantación de Identidad



Ataques : Suplantación de Personas

- Una persona o entidad se hace pasar por otra
- Muy común con el correo electrónico
 - ☐ Virus
 - ☐ Phishing
- Solución
 - ☐ Autenticación



Phishing: Ejemplos

From: **Bancolombia** <Notificaciones@Bancolombia.com.co>
Subject: Spam:Cuenta Bloqueada
Date: February 10, 2012 4:03:05 PM GMT-05:00
To: undisclosed-recipients: <"undisclosed-recipients:"@samba.icesi.edu.co>



Estimado Cliente :

Debido a la importancia por la seguridad e integridad de nuestros servicios hemos decidido enviarle el siguiente mensaje de alerta en el cual le comunicamos que debido a los reiterados intentos incorrectos para acceder a su cuenta desde nuestra sucursal virtual, su cuenta de Bancolombia ha sido temporalmente bloqueada.

Hemos implementado los procedimientos electronicos y administrativos para proteger y ayudar a prevenir el acceso no autorizado, evitar la perdida, mal uso, alteracion y hurto de los datos personales.

En Bancolombia nos preocupamos por su seguridad, por este motivo recibira esta notificacion de forma automatica cada vez que sea necesario.

Para evitar bloqueos y suspension de los servicios ofrecidos en nuestra sucursal virtual, ingrese a su cuenta de manera rapida y segura haciendo click sobre el siguiente enlace el cual lo redireccionara hacia nuestra Sucursal Virtual. Si el ingreso es exitoso nuestro sistema eliminara el bloqueo de manera inmediata y usted podra seguir disfrutando de todos nuestros servicios.

<https://www.bancolombia.com>

Bancolombia pone a tu disposicion, sin costo adicional nuevos servidores que cuentan con la ultima tecnologia en proteccion y encriptacion de datos.

GRUPOBANCOLOMBIA S.A.

Sucursal Telefonica Bancolombia: Medellin - Local: 510 90 00 - Bogota - Local: 343 00 00 -
Barranquilla - Local: 361 88 88 - Cali - Local: 554 05 05 - Resto paises: 01800 09 12345

Sucursales Telefonicas en el exterior: España 900 995 717 - Estados Unidos 1866 379 9714.
Copyright © 2008 GRUPO BANCOLOMBIA

Phishing: Ejemplos

www.grenad-in.net/cache/https/bancolombia.olb.todo.com/olb/init.html

 **Sucursal Virtual Personas**

Inicio - Sucursal Virtual

Por favor ingrese su Usuario

Aceptar

[¿Donde ingreso la clave personal?](#)

[¿Olvidé su usuario?](#) [¿No puede conectarse?](#)

A PARTIR DEL 15 DE FEBRERO DE 2012, BANCOLOMBIA MODIFICARÁ ALGUNAS DE LAS TARIFAS DE SUS PRODUCTOS Y SERVICIOS.

Invitamos a nuestros clientes a conocer más información aquí.

Se ofrecen servicios al cliente. | **Bancolombia**

[¿No conoce la Sucursal Virtual Personas de Bancolombia? Ver DEMO](#)

¿HACE CUÁNTO NO CAMBIAS TU CLAVE?

Recuerda cambiarla periódicamente para evitar fraudes.

Facturanet

Para pagar la factura del celular, Facturanet ofrece muchas ventajas.

Aprende cómo aquí

Desde ahora podrás inscribir tus facturas a través de la **Sucursal Virtual Personas** y realizar el pago de las mismas desde la **comodidad de tu casa.**

Si quieres saber cómo hacerlo, ingresa aquí

[Seguridad](#) [Política de Privacidad](#) [Política de Uso](#) [Reglamento Sucursal Virtual](#)

COPYRIGHTS (c) 2000 - 2010 TODO1 SERVICES, INC. Todos los derechos reservados

Phishing: Ejemplos

www.grenad-in.net/cache/https/bancolombia.oib.todo1.com/oib/Init.php

Sucursal Virtual Personas

Inicio - Sucursal Virtual

Por favor digite su Documento de Identidad

Por favor digite su Clave

Aceptar

Contraste

1 2 3

4 5 6

7 8 9

0 Limpia

1 2 3

A PARTIR DEL 15 DE FEBRERO DE 2012. BANCOLOMBIA MODIFICARÁ ALGUNAS DE LAS TARIFAS DE SUS PRODUCTOS Y SERVICIOS.

Invitamos a nuestros clientes a conocer más información aquí.

le estamos poniendo al día. | Bancolombia

[Generar su clave personal](#) [¿No puede conectarse?](#)

No conoce la Sucursal Virtual Personas de Bancolombia? [Ver DEMO](#)

1 Ingresarás tus datos en dos pantallas, en la primera tu documento de identidad o usuario y en la siguiente tu clave personal.

2 Registra tus computadores de uso frecuente y así nosotros podremos reconocer que eres tú quien está ingresando a la información de tus productos.

Desde ahora podrás inscribir tus facturas a través de la Sucursal Virtual Personas y realizar el pago de las mismas desde la comodidad de tu casa.

Si quieres saber cómo hacerlo, ingresa aquí

[Seguridad](#) [Política de Privacidad](#) [Política de Uso](#) [Reglamento Sucursal Virtual](#)

Seguridad de la información, Seguridad Informática, Ciberseguridad

Seguridad de la Información

Se refiere a la protección de activos de información, fundamentales para la operación y continuidad de cualquier organización.

Seguridad Informática

Se refiere a la protección de las estructuras de las tecnologías de la información y comunicación que soporta a los hogares y Organizaciones

Ciberseguridad

Conjunto de medidas de protección de la información, a través del tratamiento de las amenazas que ponen en riesgo la información que es tratada por los sistemas de información que se encuentran interconectados

Activo de Información

Es todo lo que las entidades consideran de gran validez para las mismas ya que contiene información importante para ellas. (bases de datos, archivos lógicos, físicos etc ..)



Fuente de Información

Se denominan fuentes de información a diversos tipos de documentos que contienen datos útiles para satisfacer cualquier demanda de información o conocimiento.



Seguridad de la información – ISO 27002

- ▶ De acuerdo con la norma ISO/IEC 27002, la seguridad de la información es la protección de la información contra los diversos tipos de amenazas para garantizar la continuidad del negocio, minimizando los riesgos y maximizando el retorno sobre la inversión.
- ▶ Es resultado de la implementación de un conjunto de controles, que comprenden políticas, procesos, procedimientos, estructuras organizacionales y funciones de hardware y software.

Algunos conceptos

- ▶ **Incidente de seguridad:** corresponde a cualquier evento adverso relacionado con la seguridad, por ejemplo, ataques de denegación de servicio, robo de información, fuga y la obtención de un acceso no autorizado a la información.
- ▶ **Activo:** Elemento de valor para la organización.
Ejemplo: bases de datos, software, equipos servidores, dispositivos de red , personas, procesos y servicios

Algunos conceptos

- ▶ **Amenaza:** Evento que explote vulnerabilidades. Causa potencial de un incidente no deseado, que puede resultar en daños a un sistema u organización
- ▶ **Vulnerabilidad:** cualquier debilidad que puede ser explotada y ponga en peligro la seguridad de los sistemas y datos.

Algunos conceptos

- ▶ **Riesgo:** combinación de la probabilidad (oportunidad de que la amenaza se materialice) de que ocurra un evento y sus consecuencias para la organización. Algo que puede ocurrir y sus efectos sobre los objetivos de la organización.
- ▶ **Ataque:** cualquier acción que comprometa la seguridad de una organización.
- ▶ **Impacto:** resultado evaluado de un evento en particular.



Política de Seguridad de la Información

Política de la seguridad de la Información: Diagrama



Elementos:

- ▶ Políticas
- ▶ Normas
- ▶ Procedimientos
- ▶ Instrucciones
- ▶ Evidencia

Elementos:

- ▶ Políticas
- ▶ **Normas**
- ▶ Procedimientos
- ▶ Instrucciones
- ▶ Evidencia

Elementos:

- ▶ Políticas
- ▶ Normas
- ▶ **Procedimientos**
- ▶ Instrucciones
- ▶ Evidencia

Elementos:

- ▶ Políticas
- ▶ Normas
- ▶ Procedimientos
- ▶ Instrucciones
- ▶ Evidencia

Elementos:

- ▶ Políticas
- ▶ Normas
- ▶ Procedimientos
- ▶ Instrucciones
- ▶ Evidencia

Arquitectura



Política de seguridad: Preguntas a responder

- ▶ Que se desea proteger ?
- ▶ ¿Contra qué o quién?
- ▶ ¿ Amenazas ? ¿ Las mas probables ?
- ▶ ¿Cuál es la relevancia de cada recurso a ser protegido?

Política de seguridad: Preguntas a responder

- ▶ ¿Cuál es el grado de protección requerido?
- ▶ ¿ Tiempo, recursos financieros y humanos ?

► Política de seguridad – Preguntas



Cumplimiento

Sistema de Gestión de Seguridad de la Información

Sistema de Gestión de Seguridad de la Información

Permite garantizar la seguridad de la información de toda la Organización a través de:

CONTROLES

Que nos permitan medir la eficacia de las medidas tomadas



ANALISIS

Análisis y recopilación de toda la información afectada



PROCEDIMIENTOS

Para mantener la Seguridad